UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Marzo 2026

EL ESLABÓN MÁS DÉBIL:

DISEÑO ÉTICO DE UNA CAMPAÑA DE INGENIERÍA SOCIAL.

Gisela Geraldine Moreno Solis - 176522

Maestro: Servando Contreras Lopez

CNO V: Seguridad Informatica

CONTENIDO

1. Introducción al Riesgo Humano en Ciberseguridad
2. Objetivos de la Campaña de Simulación
   - 2.1. Objetivo General
   - 2.2. Objetivos Específicos
3. Fundamentación Técnica y Marco Ético
   - 3.1. La Ingeniería Social como Vector de Ataque Principal
   - 3.2. Taxonomía de Amenazas (Phishing, Smishing, Vishing, Quishing)
   - 3.3. KPIs y Métricas Críticas de Evaluación (Tasa de Reporte vs. Tasa de Clics)
   - 3.4. Principios de Ética Digital y Diseño No Punitivo
4. Evaluación Técnica de Soluciones del Mercado
   - 4.1. Plataformas de Cambio Conductual impulsadas por IA
     - Análisis de Hoxhunt
     - Análisis de Phished
   - 4.2. Plataformas Basadas en Inteligencia de Amenazas y Respuesta (SOC)
     - Análisis de Proofpoint
     - Análisis de Cofense
     - Análisis de Mimecast
   - 4.3. Plataformas Enfocadas en Cultura, Cumplimiento y Edutainment
     - Análisis de KnowBe4
     - Análisis de NINJIO
     - Análisis de Infosec IQ
5. Matriz Comparativa de Capacidades Técnicas
6. Conclusiones y Siguientes Pasos (Diseño del Quiz)
7. Referencias Bibliográficas

1. Introducción al Riesgo Humano en Ciberseguridad

El Eslabón Más Débil de la Defensa Corporativa

En el panorama actual de la ciberseguridad, las organizaciones realizan inversiones significativas en controles técnicos avanzados, tales como firewalls y sistemas de detección de intrusiones. Sin embargo, esta infraestructura tecnológica resulta fundamentalmente insuficiente si no se aborda de manera estratégica el factor humano, el cual es comúnmente denominado como "el eslabón más débil" de la cadena de defensa.

El Auge de la Ingeniería Social

Debido a la fortaleza de los sistemas modernos, la ingeniería social se ha consolidado como la técnica preferida por los atacantes cibernéticos. La premisa detrás de esta tendencia es clara y alarmante: resulta considerablemente más sencillo manipular la psicología y las emociones de un usuario mediante el engaño, que intentar vulnerar un algoritmo de cifrado complejo o evadir arquitecturas de seguridad de red. Los ciberdelincuentes han transformado el engaño en una ciencia exacta, explotando la urgencia, la autoridad y la curiosidad de los empleados.

Planteamiento del Proyecto (PR02)

Frente a esta problemática, el presente proyecto, denominado "PR02: El eslabón más débil", se enfoca en mitigar este riesgo interno a través del diseño, implementación y evaluación ética de una campaña de simulación de phishing. A través de una exhaustiva investigación comparativa de las plataformas líderes en el mercado —tales como KnowBe4, Proofpoint y Hoxhunt— y el desarrollo práctico de un simulador interactivo (*Phishing Quiz*), se busca medir de forma tangible el nivel de preparación y resiliencia de los usuarios frente a las amenazas digitales.

El Compromiso con la Ética Digital

El diferenciador crítico de este proyecto es su enfoque centrado en el usuario. Todo el desarrollo se rige bajo principios estrictos de ética digital. Esto asegura que la metodología de evaluación y la recolección de datos tengan un propósito exclusivamente formativo y no punitivo, protegiendo en todo momento la integridad moral, profesional y la privacidad de los participantes. El objetivo no es señalar al empleado que comete un error, sino transformar ese error en una oportunidad inmediata de aprendizaje corporativo.

2. Objetivos de la Campaña de Simulación

Diseñar, implementar y evaluar de manera ética una simulación educativa de phishing. Esta iniciativa estará sustentada en un análisis comparativo profundo de las principales plataformas profesionales del mercado. El propósito central es medir con precisión el nivel de reconocimiento de amenazas de ingeniería social en los usuarios finales. Finalmente, se busca interpretar estos resultados mediante la creación de un sistema de puntuación global, el cual servirá como base para fomentar una reflexión crítica e institucional sobre la gestión responsable del riesgo humano en los entornos de seguridad informática.

Objetivos Específicos

Para alcanzar el objetivo general, el proyecto se estructura en las siguientes metas técnicas y operativas:

- **Auditoría y Análisis de Mercado:** Analizar y comparar exhaustivamente ocho plataformas profesionales líderes en la simulación de phishing (Hoxhunt, Proofpoint, KnowBe4, Cofense, Phished, NINJIO, Mimecast e Infosec IQ). Esta evaluación identificará sus capacidades técnicas diferenciadoras, sus métricas de medición (KPIs) y sus respectivos enfoques éticos hacia el usuario.
- **Diseño de la Herramienta de Evaluación:** Diseñar e implementar un simulador interactivo estructurado como un *Phishing Quiz*. Este instrumento constará de 10 escenarios realistas de ingeniería social, incorporando estrictos criterios de evaluación técnica y garantizando la entrega de retroalimentación formativa de manera inmediata en el punto de falla.
- **Desarrollo de Analítica de Datos:** Desarrollar e interpretar un sistema de *score* (puntuación) global que consolide de manera segura los resultados de todos los participantes. Esta métrica permitirá analizar tendencias de vulnerabilidad, identificar los vectores de ataque más efectivos y detectar áreas de oportunidad clave en la estrategia de concienciación en ciberseguridad.
- **Garantía de Integridad y Privacidad:** Asegurar el cumplimiento ético irrestricto durante toda la ejecución de la campaña. Esto se logrará mediante la implementación formal de consentimientos informados y la omisión absoluta en la captura de credenciales reales o datos sensibles. El diseño priorizará, en todo momento, el proceso de aprendizaje constructivo sobre la exposición o penalización punitiva de los usuarios.

3. Marco Teórico y Fundamentación Técnica

3.1. La Ingeniería Social: El Factor Humano

La ingeniería social se conceptualiza como el despliegue de tácticas de manipulación psicológica orientadas a coaccionar o persuadir a los usuarios para que ejecuten acciones perjudiciales, tales como la divulgación de información confidencial o la instalación de software malicioso. Dentro de la arquitectura de ciberseguridad, el factor humano representa invariablemente el "eslabón más débil" de la cadena de defensa defensiva. A diferencia de los controles tecnológicos deterministas (como un firewall o un antivirus), la conducta humana es inherentemente impredecible y altamente susceptible a la explotación mediante el engaño emocional.

3.2. Métricas Críticas de Evaluación (KPIs)

Para auditar la efectividad real de una campaña de simulación de phishing, es imperativo trascender el simple conteo de errores y adoptar un modelo de Indicadores Clave de Rendimiento (KPIs) multidimensional:

- **Tasa de Clics (Click Rate):** Cuantifica el porcentaje de usuarios que interactuaron directamente con el elemento malicioso, ya sea un enlace o un archivo adjunto. Un Click Rate elevado es un indicador de una vulnerabilidad crítica dentro de la cultura de seguridad de la organización.

- **Macro-Conversión (Macro-Conversion):** Representa una escalada en el nivel de riesgo. Ocurre cuando el usuario no se limita a dar clic, sino que completa una acción secundaria comprometedora, como el intento de descarga de un archivo o la introducción de credenciales en una página de inicio de sesión fraudulenta.
- **Tasa de Reporte (Reporting Rate):** Constituye la métrica de éxito proactivo por excelencia. Mide la proporción de usuarios que emplearon las herramientas de alerta corporativas (como el botón de reporte de phishing) para notificar al equipo de seguridad sobre la presencia de la amenaza.
- **Puntuación de Resiliencia (Resilience Score):** Es un algoritmo que triangula la tasa de clics frente a la tasa de reporte. Este cálculo determina la verdadera capacidad de "supervivencia" o resiliencia de un departamento ante un ataque cibernético real.

3.3. Vectores de Ataque en Ingeniería Social

Las campañas modernas de ciberdelincuencia han diversificado sus puntos de entrada, extendiéndose mucho más allá del correo electrónico tradicional. Los vectores de ataque de mayor prevalencia incluyen:

1. **Phishing:** Despliegue de correos electrónicos fraudulentos diseñados para suplantar identidades corporativas o servicios legítimos.
2. **Smishing (SMS Phishing):** Ejecución de ataques a través de mensajes de texto (SMS) que incrustan enlaces maliciosos hacia portales falsos.
3. **Vishing (Voice Phishing):** Ingeniería social orquestada mediante llamadas telefónicas tradicionales o plataformas de voz sobre IP (VoIP), utilizando tácticas de urgencia o autoridad.
4. **Quishing (QR Phishing):** El uso estratégico de códigos QR alterados u ocultos que, al ser escaneados por dispositivos móviles, redirigen de inmediato a sitios web de captura de credenciales.

3.4. Enfoques de Entrenamiento y Ética

El núcleo de este proyecto (PR02) se rige por un marco de trabajo estrictamente ético y pedagógico:

- **Momento de Aprendizaje (Teachable Moment):** Este principio educativo postula que la asimilación del conocimiento es sustancialmente más efectiva cuando la retroalimentación se entrega en el instante inmediatamente posterior al error del usuario.
- **Diseño Ético No Punitivo:** Una campaña de simulación responsable debe erradicar por completo la técnica del *shaming* (avergonzar o exponer al empleado). El objetivo central no radica en castigar o señalar la vulnerabilidad, sino en fortalecer la capacidad analítica y de detección a través de la gamificación y el refuerzo positivo continuo.
- **Privacidad de Datos Absoluta:** Bajo los estándares de una simulación ética, bajo ninguna circunstancia se deben capturar o almacenar contraseñas reales ni datos personales sensibles. La infraestructura de la plataforma únicamente debe registrar la métrica binaria de si el usuario "habría caído" o no en el escenario de ataque.

4. Evaluación Técnica de Soluciones del Mercado

Para fundamentar el diseño del *Phishing Quiz* de este proyecto, se realizó una auditoría técnica de ocho plataformas líderes en la industria. El análisis se ha categorizado en tres ejes estratégicos según su enfoque tecnológico principal:

4.1. Plataformas de Cambio Conductual impulsadas por IA

Estas soluciones buscan automatizar la concienciación minimizando la carga operativa del equipo de TI, confiando en algoritmos de aprendizaje automático para personalizar la experiencia.

- **Hoxhunt:**
  - **Filosofía y Capacidades:** No se define como un simulador tradicional, sino como una plataforma de Transformación del Comportamiento Humano. Utiliza un modelo de Inteligencia Artificial Adaptativa (*Adaptive Learning*) que ajusta la dificultad de los escenarios de forma hiperpersonalizada. Se integra mediante un *add-in* nativo en clientes de correo (Outlook/Gmail) para facilitar el reporte.
  - **Analítica:** Evalúa la resiliencia corporativa a través de métricas como *Success Rate* (reportes), *Miss Rate* (ignorados) y *Fail Rate* (clics).
  - **Enfoque Ético:** Su pilar es la gamificación y el refuerzo positivo. Cumple con el GDPR y mantiene el anonimato de los fallos individuales frente a los gerentes, evitando la victimización y el estrés laboral.
- **Phished:**
  - **Filosofía y Capacidades:** Opera como un sistema de "piloto automático" impulsado por un algoritmo de autoaprendizaje conductual. Destaca por su capacidad de ejecutar simulaciones multicanal, abarcando Phishing, Smishing y Vishing.
  - **Analítica:** Trasciende los gráficos estáticos mediante su *Behavioral Index* (Índice de Comportamiento individual) y el *Risk Reduction Score*, automatizando la generación de reportes ejecutivos.
  - **Enfoque Ético:** Basado en el principio de *Privacy by Design* conforme al GDPR europeo. La IA funciona como un "entrenador personal", eliminando el sesgo punitivo de la administración humana.

4.2. Plataformas Basadas en Inteligencia de Amenazas y Respuesta (SOC)

Estas herramientas integran la concienciación con la defensa perimetral, buscando que el empleado actúe como un sensor de amenazas en tiempo real para el Centro de Operaciones de Seguridad (SOC).

- **Proofpoint (Security Awareness Training):**
  - **Filosofía y Capacidades:** Implementa una "Seguridad Centrada en las Personas". Su diferenciador técnico es la identificación de VAPs (*Very Attacked People*), priorizando el entrenamiento para aquellos usuarios que son blancos de ataques dirigidos reales interceptados por sus firewalls.
  - **Analítica:** Utiliza un *Vulnerability Score* que cruza el desempeño en simulaciones con el volumen de ataques reales recibidos, ofreciendo además comparativas industriales.

    - **Enfoque Ético:** Promueve la transparencia y la protección preventiva. Al identificar a los VAPs, permite aplicar políticas estrictas (como MFA) solo a perfiles de alto riesgo, sin mermar la productividad del resto del personal.
- **Cofense (PhishMe):**
    - **Filosofía y Capacidades:** Su premisa es que la detección humana supera a las máquinas. Transforma al empleado en un sensor activo mediante herramientas como *Cofense Reporter* y *Cofense Triage*, las cuales procesan correos reportados en tiempo real.
    - **Analítica:** Prioriza la capacidad de respuesta midiendo el MTTR (*Mean Time to Report*) y la *Reporter Accuracy* (precisión del reporte).
    - **Enfoque Ético:** Fomenta un ecosistema colaborativo que celebra activamente al usuario que reporta la amenaza, sustituyendo la vigilancia punitiva por la responsabilidad compartida.
- **Mimecast (Awareness Training):**
    - **Filosofía y Capacidades:** Su arquitectura es de "Seguridad Integrada", funcionando dentro de su propio Gateway de correo. Su funcionalidad *Safe Phish* convierte ataques reales neutralizados en simulaciones seguras.
    - **Analítica:** Proporciona una visión de riesgo integral mediante el *SAFE Score* corporativo y analiza no solo los clics, sino la recurrencia en los intentos de acceso a sitios bloqueados.
    - **Enfoque Ético:** Desestigmatiza el error humano utilizando módulos de video cortos basados en la comedia. Su enfoque es defensivo, cifrando los datos para cumplir con normativas como ISO 27001 e HIPAA.

4.3. Plataformas Enfocadas en Cultura, Cumplimiento y Edutainment

Soluciones diseñadas para construir resiliencia a largo plazo mediante marcos normativos o narrativas de alto impacto emocional.

- **KnowBe4:**
    - **Filosofía y Capacidades:** Pionero en el *Human Risk Management* (HRM) con una extensa biblioteca de contenidos. Utiliza un agente de IA (AIDA) y herramientas complementarias para simular ataques físicos (USB) y de ransomware inofensivo (*RanSim*).
    - **Analítica:** Su métrica insignia es el *Phish-prone Percentage*, complementada con el *Personal Risk Score* y encuestas de cultura de seguridad (SCS).
    - **Enfoque Ético:** Aplica el *Teachable Moment* mediante páginas de aterrizaje que explican pedagógicamente las señales de peligro ignoradas, evitando castigos directos.
- **NINJIO:**
    - **Filosofía y Capacidades:** Revoluciona el sector mediante el *Edutainment* (educación y entretenimiento) y el *Storytelling*. Produce episodios de animación estilizada, guionados profesionalmente y basados en brechas corporativas reales.
    - **Analítica:** Su *NINJIO Risk Algorithm* evalúa el compromiso del usuario y la retención del conocimiento, fomentando la gamificación interdepartamental.
    - **Enfoque Ético:** Apela a la empatía y al humor, mostrando a las víctimas como personas manipuladas profesionalmente, lo que reduce dramáticamente el estigma asociado a reportar un ciberataque.

- **Infosec IQ:**
    - **Filosofía y Capacidades:** Destaca por su estricta alineación con el marco de trabajo del NIST (*National Institute of Standards and Technology*). Ofrece contenido localizado en más de 34 idiomas y cuenta con el módulo *Infosec Skills* para perfiles técnicos.
    - **Analítica:** Evalúa el nivel técnico a través del *IQ Score* y genera mapas de habilidades granulares para identificar deficiencias específicas por departamento.
    - **Enfoque Ético:** Promueve una cultura positiva fundamentada en la educación basada en roles, entregando a cada empleado únicamente la capacitación pertinente a su nivel de exposición y funciones.

5. Matriz Comparativa de Capacidades Técnicas

Para consolidar la auditoría de las ocho soluciones evaluadas, se presenta la siguiente matriz técnica. Esta herramienta permite visualizar rápidamente las fortalezas, limitaciones operativas y el nivel de cumplimiento normativo de cada plataforma, facilitando la toma de decisiones para el despliegue de futuras campañas.

Plataforma	Factor Diferenciador	Métricas Clave (KPIs)	Integración Técnica	Enfoque Ético	Limitaciones Operativas	Cumplimiento Normativo
Hoxhunt	Gamificación extrema y recompensas conductuales.	Tasa de reporte y éxito en simulaciones.	Add-in nativo y fluido en Outlook/Gmail.	Refuerzo positivo; estrictamente no punitivo.	Dependencia total de la IA; vulnerabilidad en telemetría si el add-in falla.	GDPR (Privacidad por diseño).
Proofpoint	Enfoque preventivo en VAPs (Personas Muy Atacadas).	Vulnerability Score integrado con amenazas.	Ecosistema cerrado de seguridad de correo.	Transparencia y protección preventiva del usuario.	Costo de implementación elevado; exige infraestructura robusta.	NIST, FISMA, GDPR.
KnowBe4	Biblioteca masiva de contenidos y motor IA (AIDA).	Phish-prone Percentage y Risk Score individual.	Alta flexibilidad (AD, Azure, APIs).	Teachable Moments y educación inmediata.	Curva de aprendizaje compleja para los nuevos administradores.	GDPR, SOC2, HIPAA, PCI DSS.
Cofense	Inteligencia colectiva mediante botón de reporte	Mean Time to Report (MTTR).	Alta integración directa con SOC y plataformas	Colaboración y empoderamiento del reporte	Requiere un equipo de IT/SOC dedicado para analizar	SOC2 Type II, FedRAMP.

	activo.		SOAR.	activo.	y triar los reportes.	
Phished	IA de autoaprendizaje con intervención humana nula.	Behavioral Index (Índice de comportamiento individual).	Automatización completa vía API y ecosistema Cloud.	Privacy by Design y anonimato.	Menor flexibilidad para el diseño manual de campañas altamente específicas.	GDPR, ISO 27001.
NINJIO	Storytelling interactivo con producción estilo anime.	Engagement continuo y retención emocional.	Portal LMS propio o integración estándar vía SCORM.	Empatía hacia la víctima y reducción del estigma.	El contenido en video en alta definición puede demandar alto ancho de banda.	HIPAA, GDPR, NIST.
Mimecast	Integración nativa e invisible con el Gateway de correo.	SAFE Score (comparativa versus la industria).	Seguridad Híbrida (Inline Gateway).	Protección defensiva mediante humor desestigmatizante.	Altamente complejo de implementar si no se utiliza su gateway de correo principal.	ISO 27001, HIPAA, SOC2.
Infosec IQ	Alineación técnica estricta con los estándares del NIST.	IQ Score y generación de mapas de habilidades.	Plataforma SaaS con módulos de aprendizaje interactivos.	Fomento de una cultura de seguridad inclusiva y positiva.	Interfaz de administración menos intuitiva comparada con sus competidores directos.	NIST (Mapeo total de directrices), GDPR.

6. Conclusiones y Siguientes Pasos (Diseño del Quiz)

Tras el análisis exhaustivo de las ocho plataformas, se concluye que la gestión del riesgo humano ha trascendido el entrenamiento estático para convertirse en una arquitectura de defensa conductual fundamentada en datos. La efectividad de una campaña ya no reside en engañar al usuario con señuelos sofisticados, sino en la personalización de la respuesta tecnológica ante su comportamiento.

Un hallazgo crítico de esta investigación es que la métrica suprema para evaluar la resiliencia corporativa no es la "Tasa de Clics", sino el *Reporting Rate* (Tasa de Reporte) ; transformar al usuario en un sensor activo disminuye exponencialmente los tiempos de exposición ante amenazas. Asimismo, la industria ha consolidado el diseño ético y el

Teachable Moment como el estándar innegociable , asegurando que la educación ocurra en el punto exacto de falla sin comprometer la moral del empleado.

Siguientes Pasos: Arquitectura del *Phishing Quiz*

Para materializar estos principios en el entregable final de este proyecto (PR02), se diseñará un simulador interactivo estructurado en 10 escenarios que medirán vectores psicológicos específicos, garantizando retroalimentación inmediata y la total privacidad de los datos:

1. **Urgencia Tecnológica:** Falsa alerta de soporte técnico exigiendo cambio de contraseña inmediato.
2. **Autoridad (Whaling):** Mensaje simulado del CEO solicitando la compra urgente de tarjetas de regalo.
3. **Curiosidad Corporativa:** Correo de Recursos Humanos con un falso "PDF de Políticas de Bonos".
4. **Miedo (Alerta de Nube):** Advertencia fraudulenta de inicio de sesión inusual en Microsoft 365.
5. **Expectativa (Smishing):** SMS de paquetería (DHL/FedEx) solicitando un pago por retención aduanal.
6. **Confianza Profesional:** Falsa notificación de LinkedIn sobre una oferta laboral de alto perfil.
7. **Pánico Financiero:** Envío de una factura inflada de un proveedor de servicios básicos.
8. **Curiosidad Física (Baiting):** Escenario de toma de decisión ante una memoria USB abandonada etiquetada como "Nómina Confidencial".
9. **Familiaridad:** Notificación fraudulenta de grabación compartida en Zoom o Teams.
10. **Oportunismo:** Correo promocionando un descuento exclusivo irreal para empleados en equipos tecnológicos.

7. Referencias Bibliográficas

Toda la investigación técnica y comparativa de este informe está sustentada en la siguiente documentación:

- Cofense. (2026). *Phishing Detection and Response (PDR) Solutions: Technical Overview and Collective Intelligence.* Recuperado de https://cofense.com/.
- Hoxhunt. (2024). *The Science of Behavior Change in Cybersecurity: Human Risk Management and Adaptive AI.* Recuperado de https://www.hoxhunt.com/.
- Infosec Institute. (2026). *Security Awareness Training and Phishing Simulations: Infosec IQ NIST Mapping and Role-Based Training.* Recuperado de https://www.infosecinstitute.com/iq/.
- KnowBe4. (2026). *2026 Phishing by Industry Benchmarking Report: Measuring the Phish-prone™ Percentage.* Recuperado de https://www.knowbe4.com/.
- Mimecast. (2026). *The State of Email Security 2026: Awareness Training Integration and SAFE Score Metrics.* Recuperado de https://www.mimecast.com/.
- National Institute of Standards and Technology (NIST). (2022). *Introduction to Cybersecurity for Human Resources (NIST SP 800-50).* U.S. Department of Commerce.

- NINJIO. (2026). *Cybersecurity Awareness Training: The Power of Narrative Storytelling and Emotional Engagement.* Recuperado de https://ninjio.com/.
- Phished. (2026). *AI-Driven Behavioral Change and Automated Phishing Simulations for Organizations.* Recuperado de https://phished.io/.
- Proofpoint. (2024). *State of the Phish 2024: Identifying and Protecting Very Attacked People (VAPs).* Recuperado de https://www.proofpoint.com/.